



Programa de conformidade de segurança da AWS

© 2020, Amazon Web Services, Inc. ou uma afilizada. Todos os direitos reservados.

Boas-vindas a Programa de conformidade de segurança da AWS.



O que você aprenderá

Principais pontos da lição

Você aprenderá a:

- Descrever o programa de conformidade de segurança da AWS
- Explorar os três componentes do programa de conformidade e riscos da AWS



Esta lição explora os seguintes tópicos:

- A abordagem de conformidade da AWS, que inclui programas de garantia
- Programas de conformidade e riscos da AWS, como gerenciamento de riscos, ambiente de controle e segurança da informação
- Responsabilidades de conformidade do cliente da AWS

Abordagem de conformidade da AWS

Responsabilidade da AWS

- Fornecer ambientes altamente seguros e controlados.
- Fornecer uma ampla variedade de recursos de segurança.



Responsabilidade do cliente:

- Configurar a TI.

Conforme descrito no modelo de responsabilidade compartilhada para segurança, a AWS e seus clientes compartilham o controle sobre o ambiente de TI. Isso significa que ambas as partes são responsáveis pelo gerenciamento do ambiente de TI. Nesse modelo, a responsabilidade da AWS inclui o fornecimento de serviços em um ambiente controlado altamente seguro e uma variedade de recursos de segurança para os clientes usarem.

A responsabilidade do cliente inclui a configuração de seus ambientes de TI de forma segura e controlada para os seus propósitos.

Informações de segurança da AWS

Como a AWS compartilha informações de segurança

- Obtém certificações do setor
- Publica práticas de segurança e controle
- Fornece documentação diretamente por meio de acordos de confidencialidade (NDAs)



4

aws re/start

A AWS comunica informações sobre seu ambiente de segurança e controle relevante aos clientes. A AWS fornece informações de segurança das seguintes maneiras:

- Obtém atestados de terceiros independentes e certificações do setor.
- Publica informações sobre as práticas de segurança e controle da AWS nos documentos técnicos e no conteúdo do site.
- Fornece certificados, relatórios e outras documentações diretamente aos clientes da AWS sob acordos de confidencialidade (NDAs), conforme necessário.



Programas de garantia da AWS

A AWS, os órgãos de certificação e os auditores independentes fornecem:

- Certificações e atestados
- Leis, regulamentos e privacidade
- Frameworks para alinhamento e governança do setor



A AWS contrata órgãos de certificação externos e auditores independentes para fornecer aos clientes informações sobre as políticas, os processos e os controles estabelecidos e operados pela AWS:

- **Certificações e atestados:** certificações e atestados de conformidade são avaliados por um auditor independente externo. Eles resultam em uma certificação, um relatório de auditoria ou um atestado de conformidade.
- **Leis, regulamentações e privacidade:** os clientes da AWS permanecem responsáveis pela conformidade com as leis e os regulamentos de conformidade aplicáveis. Em alguns casos, a AWS oferece funcionalidade para dar suporte à conformidade do cliente. Exemplos dessa funcionalidade incluem recursos de segurança, ativadores e contratos legais, como o Acordo de Processamento de Dados da AWS e o Adendo de Associado Comercial.
- **Alinhamentos e frameworks do setor:** os alinhamentos e os frameworks de conformidade incluem requisitos publicados de segurança ou conformidade com determinado propósito, como uma função ou um setor específico. A AWS disponibiliza funcionalidades, como recursos de segurança, e também

oferece manuais de conformidade, documentos de mapeamento e



Programa de conformidade e riscos da AWS

Programa de conformidade e riscos da AWS

- Fornece informações sobre os controles da AWS
- Auxilia os clientes a documentar o framework

Componentes de conformidade e riscos da AWS

- Gerenciamento de riscos empresariais
- Ambiente de controle e automação
- Segurança da informação (SI)

A AWS fornece informações sobre seu programa de conformidade e riscos para permitir que os clientes incorporem os controles da AWS em sua estrutura de governança. Essas informações podem ajudar os clientes a documentar um framework completo de controle e governança com a AWS incluída como parte importante desse framework.

O programa de conformidade e riscos da AWS é composto por três elementos:

- Gerenciamento de riscos empresariais
- Ambiente de controle e automação
- Segurança da informação

Os próximos tópicos exploram cada um dos programas de conformidade e riscos da AWS com mais detalhes.

Gerenciamento de riscos da AWS

Plano de negócios e responsabilidades

Plano de negócios

- Inclui gerenciamento de riscos
- Plano reavaliado no mínimo semestralmente

Responsabilidades do cliente

- Identificação de riscos
- Implementar medidas adequadas para enfrentar os riscos
- Avaliar os diversos riscos internos ou externos

Políticas e framework de segurança da informação

- Control Objectives for Information and related Technology (COBIT)
- American Institute of Certified Public Accountants (AICPA)
- National Institute of Standards and Technology (NIST)

O gerenciamento da AWS desenvolve um plano estratégico empresarial, que inclui a identificação de riscos e a implementação de controles para reduzir ou gerenciar riscos. O gerenciamento da AWS reavalia o plano estratégico empresarial pelo menos semestralmente. Esse processo exige gerenciamento para identificar riscos em suas áreas de responsabilidade, bem como para implementar medidas adequadas projetadas para solucionar esses riscos.

Além disso, o ambiente de controle da AWS também está sujeito a várias avaliações de risco internas e externas.

A equipe de conformidade e segurança da AWS estabelece um framework e políticas de segurança da informação com base nos seguintes órgãos governamentais:

- Control Objectives for Information and related Technology (COBIT)
- American Institute of Certified Public Accountants (AICPA)
- National Institute of Standards and Technology (NIST)

Gerenciamento de riscos da AWS (continuação)

Responsabilidades da AWS

- Manter a política de segurança
- Fornecer treinamento de segurança para seus funcionários
- Executar avaliações de segurança de aplicativos
 - Confidencialidade, integridade e disponibilidade de dados
 - Conformidade com a política de SI

Segurança da AWS

- Verifica os endpoints de serviço em busca de vulnerabilidades
- Notifica para correção de vulnerabilidades

Empresas de segurança independentes

- As verificações não substituem as verificações do cliente.
- Os clientes podem pedir para verificar a infraestrutura da nuvem.

A AWS mantém a política de segurança, fornece treinamento de segurança para funcionários e realiza análises de segurança de aplicativos. Essas análises avaliam a confidencialidade, a integridade e a disponibilidade dos dados, além da conformidade com a política de segurança da informação (SI).

A AWS mantém a política de segurança, fornece treinamento de segurança para funcionários e realiza análises de segurança de aplicativos. Essas análises avaliam a confidencialidade, a integridade e a disponibilidade dos dados, além da conformidade com a política de segurança da informação (SI).

AWS

A segurança da AWS verifica regularmente se há vulnerabilidades em todos os endereços IP públicos de endpoint de serviço. No entanto, as verificações não são realizadas nas interfaces de instância do Amazon Elastic Compute Cloud (Amazon EC2) do cliente. A segurança da AWS notifica as partes apropriadas para corrigir as vulnerabilidades identificadas.

Empresas de segurança independentes

Além disso, avaliações de ameaças de vulnerabilidade externa são realizadas regularmente por empresas de segurança independentes. As descobertas e as recomendações resultantes dessas avaliações são categorizadas e entregues à liderança da AWS. Essas verificações são feitas para validar a integridade e a viabilidade da infraestrutura subjacente da AWS. Elas não se destinam a substituir as verificações de vulnerabilidades do próprio cliente necessárias para

Ambiente de controle da AWS

Ambiente de controle

- Inclui políticas, processos e atividades de controle
- Garante a entrega de ofertas de serviços da AWS

Componentes

- Pessoas
- Processos
- Tecnologia

Funcionalidade

- Oferece suporte à eficácia operacional do framework de controle da AWS
- Integra controles identificados por órgãos de nuvem líderes do setor
- Acompanha ideias de práticas líderes para gerenciar o ambiente de controle

9

A AWS gerencia um ambiente de controle abrangente que inclui políticas, processos e atividades de controle que usam vários aspectos do ambiente de controle geral da Amazon. Esse ambiente de controle está em vigor para a entrega segura de ofertas de serviços da AWS. O ambiente de controle coletivo abrange as pessoas, os processos e a tecnologia necessários para permitir a eficácia operacional do framework de controle da AWS.

A AWS integra controles específicos de nuvem aplicáveis identificados pelos principais órgãos do setor de computação em nuvem ao framework de controle da AWS. A AWS continua monitorando esses grupos do setor em busca de ideias sobre quais práticas líderes podem ser implementadas. A AWS acompanha os grupos para ajudar os clientes a gerenciar seu ambiente de controle.

Segurança da informação

Programa de segurança da informação da AWS

- Protege
 - Confidencialidade
 - Integridade
 - Disponibilidade
- Publicação de documento técnico de segurança

A AWS tem um programa formal de segurança da informação projetado para proteger a confidencialidade, a integridade e a disponibilidade dos sistemas e

A AWS tem um programa formal de segurança da informação projetado para proteger a confidencialidade, a integridade e a disponibilidade dos sistemas e dados dos clientes.

A AWS tem publicado um documento técnico de segurança que aborda como ela ajuda os clientes a protegerem seus dados.

Para obter mais informações, consulte [Conformidade da AWS](#) na página de segurança na nuvem AWS.

Requisitos de conformidade do cliente

- Manter a governança em todo o ambiente de controle de TI.
- Compreender:
 - Os objetivos de conformidade necessários
 - A tolerância de risco baseada em validação
- Estabelecer um ambiente de controle que atenda aos objetivos.
- Verificar a eficácia do ambiente de controle.
- Usar a abordagem básica de conformidade:
 - Revisão
 - Design
 - Identificar
 - Verificar

Os clientes da AWS devem manter uma governança adequada em todo o ambiente de controle de TI, independentemente de como a TI é implantada.

Os clientes da AWS devem manter uma governança adequada em todo o ambiente de controle de TI, independentemente de como a TI é implantada. As principais práticas incluem a compreensão dos objetivos e requisitos de conformidade exigidos (de fontes relevantes) e o estabelecimento de um ambiente de controle que atenda a esses objetivos e requisitos. Essas práticas também incluem uma compreensão da validação necessária com base na tolerância ao risco da organização e a verificação da eficácia operacional de seu ambiente de controle. A implantação na nuvem AWS oferece às empresas diferentes opções para aplicar diversos tipos de controles e vários métodos de verificação.

A governança e conformidade rígida do cliente podem incluir a seguinte abordagem básica:

- Analise as informações da AWS junto com outras informações para entender o máximo possível de todo o ambiente de TI. Depois, documente todos os requisitos de conformidade.
- Projete e implemente os objetivos de controle para atender aos requisitos de conformidade empresarial.
- Identifique e documente controles pertencentes a terceiros.
- Verifique se todos os objetivos de controle são atendidos e todos os controles principais foram projetados com eficiência e se apresentam bom funcionamento.

Principais conclusões



© 2020, Amazon Web Services, Inc. ou suas afiliadas. Todos os direitos reservados.

12

- A conformidade da nuvem AWS permite que os clientes **entendam os controles robustos** que existem na AWS **para manter a segurança e a proteção de dados na nuvem**.
- Os clientes operam em um ambiente **controlado pela segurança da AWS**. Como os sistemas do cliente são criados com base na infraestrutura da nuvem AWS, **as responsabilidades de conformidade são compartilhadas**.
- A AWS é compatível com vários padrões de segurança e certificações de conformidade. Esses padrões e certificações ajudam os clientes a **satisfazer os requisitos de conformidade para praticamente todas as agências reguladoras em todo o mundo**.



As principais conclusões desta lição:

- A conformidade da nuvem AWS permite que os clientes entendam os controles robustos que existem na AWS para manter a segurança e a proteção de dados na nuvem.
- Os clientes operam em um ambiente controlado pela segurança da AWS. Como os sistemas do cliente são criados com base na infraestrutura da